



CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

Incidentes de Ciberseguridad

TEMA 1

Desarrollo de Planes de Prevención y Concienciación en Ciberseguridad

Alberto Diéguez Álvarez

Contenido

Apartado 1: Diseño del esquema de una Empresa Ficticia.....	3
Información básica para diseñar el esquema de la empresa:	3
Con la información proporcionada deberás efectuar las siguientes tareas:	
.....	4
➤ Crear una lista con todos los activos de la empresa detectados en cada una de las zonas.....	4
➤ Crear un Diagrama de Bloques gráfico de la Empresa Ficticia según la estructura pedida en el que se distribuyan los activos de la lista anterior, es decir, un esquema general de los equipos distribuidos en la red según esta estructura en trípode. Para la realización de este diseño se puede usar la herramienta que se considere más idónea. Se recomienda el uso de draw.io que viene integrada en el Drive de Google o se puede optar por otras alternativas integradas en suites ofimáticas. Una vez completado el diagrama, exporta la imagen del mismo. Este diagrama formará parte de la solución que entregarás en este apartado.	
5	
Apartado 2: Detalle de los Activos Clave que se deberán auditar.....	6
Apartado 3: Comprobación prioritaria a efectuar para cada uno de los activos anteriores.....	7
Apartado 4: Auditoría prioritaria por activo (una por cada activo, sin repetir tipo)	9
Webgrafía:.....	14

¿Qué te pedimos que hagas?

Apartado 1: Diseño del esquema de una Empresa Ficticia.

Información básica para diseñar el esquema de la empresa:

- La empresa ficticia es una **joven PYME industrial** dedicada a la fabricación de repuestos para el sector automotriz. Como empresa orientada a la producción y gestión de inventarios, utiliza tanto Tecnologías de la Información (TI) para sus operaciones administrativas y comerciales, como Tecnologías de Operación (OT) para la gestión y control de los procesos fabriles. Dado que esta empresa depende de sistemas de información para la continuidad de sus operaciones y protección de datos, se ha establecido una arquitectura de red basada en tres zonas principales, conocidas como estructura en trípode.
- La empresa se organiza en tres bloques principales que permiten separar los activos de TI y OT y gestionar los accesos de manera controlada:
 1. **LAN (Red Interna de Gestión Empresarial):** Esta red interna incluye todos los sistemas y servicios necesarios para la gestión empresarial y el soporte administrativo. Entre sus activos se encuentran los puestos de trabajo de los empleados, tanto locales como remotos, y los sistemas de bases de datos y almacenamiento para el ERP (Enterprise Resource Planning), utilizados para el manejo de la información económica y financiera. Además, aquí se encuentran los sistemas de análisis avanzados, como Big Data, IA y Machine Learning, empleados para mejorar la toma de decisiones estratégicas.
 2. **DMZ (Zona Desmilitarizada):** Esta zona se encuentra segmentada de la red interna y la red externa (Internet), y su función principal es albergar los servicios que deben estar expuestos parcialmente a Internet. La DMZ de la empresa contiene el Centro de Operaciones de Seguridad (SOC), desde donde se monitorizan los eventos de seguridad; un IDS (Sistema de Detección de Intrusiones) y SIEM (Gestión de Información y Eventos de Seguridad) para la detección y gestión de incidentes; y el NAS (Network Attached Storage) y Vault, que almacenan documentos de diseño y planos protegidos. Adicionalmente, en esta zona se encuentran un portal web para la presencia pública de la empresa y un servidor de laboratorio destinado a pruebas de software y aplicaciones internas.

3. **Smart Factory (Red de Operación Fabril, aislada de Internet):** En esta zona se agrupan todos los sistemas relacionados con la producción y el control de los procesos fabriles. La red de la Smart Factory incluye el sistema ERP y el MES (Manufacturing Execution System), que se usan para la gestión de la producción y el control del inventario. Además, en esta zona se encuentra el sistema SCADA para la supervisión y control en tiempo real de los procesos industriales, los PLC (Controladores Lógicos Programables) que gestionan la maquinaria automatizada y los dispositivos fabriles como sensores y actuadores. Estos activos no están expuestos a Internet para reducir riesgos de ciberseguridad y asegurar la continuidad operativa.

Con la información proporcionada deberás efectuar las siguientes tareas:

- Crear una lista con todos los activos de la empresa detectados en cada una de las zonas.

LAN Red Interna de Gestión Empresarial

- Puesto de trabajo de los empleados, locales y remotos.
- Sistemas de bases de datos para el ERP (Enterprise Resource Planning)
- Sistemas de almacenamiento para el ERP (Enterprise Resource Planning)
- Sistemas de análisis avanzados Big Data
- Sistemas de análisis avanzados IA y Machine Learning

DMZ (Zona Desmilitarizada)

- Centro de Operaciones de Seguridad (SOC)
- IDS (Sistema de Detección de Intrusiones)
- SIEM (Gestión de Información y Eventos de Seguridad)
- NAS (Network Attached Storage)
- Vault, que almacenan documentos
- Portal web
- Servidor de laboratorio

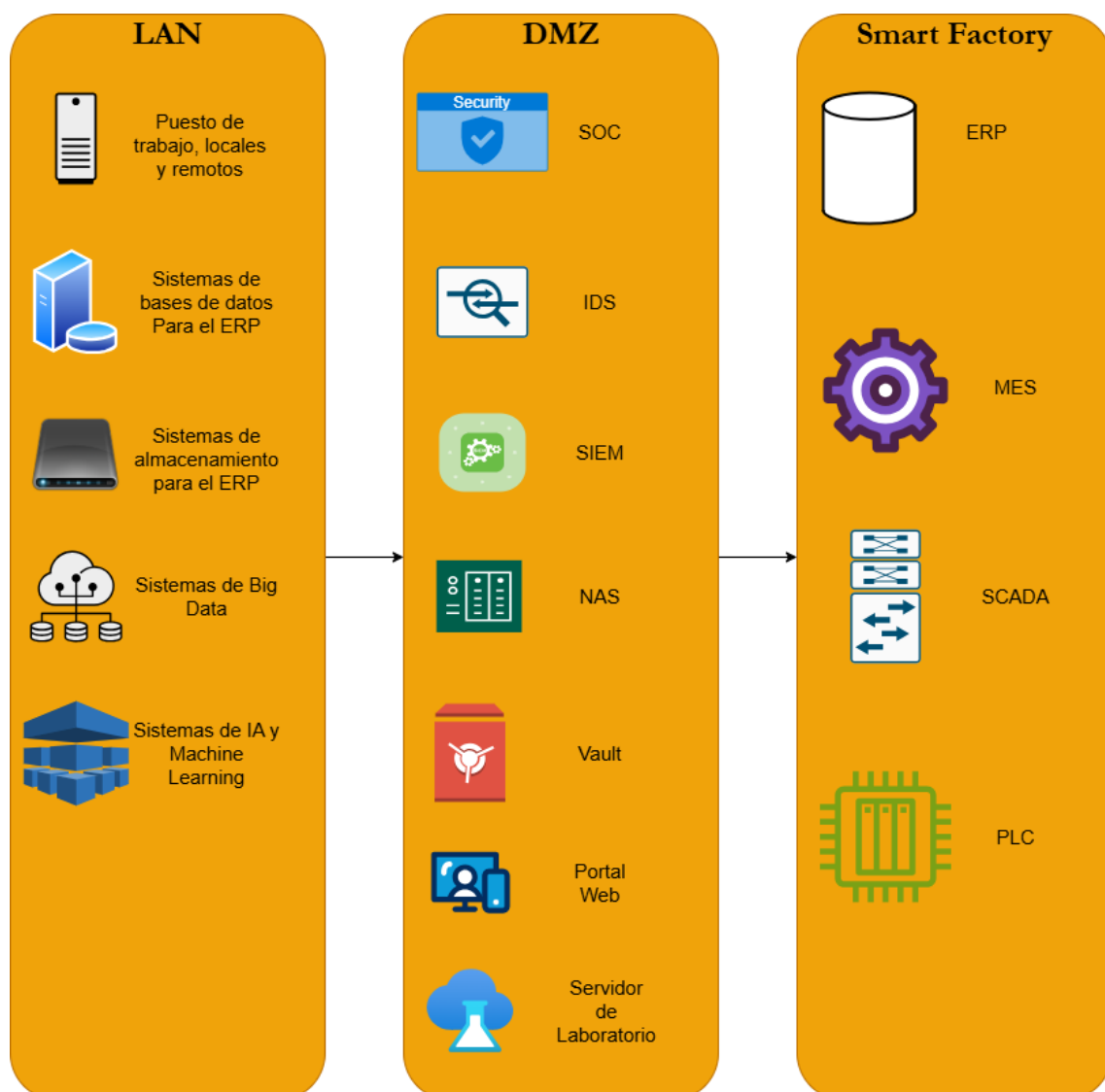
Smart Factory (Red de Operación Fabril, aislada de Internet)

- Sistema ERP
- Sistemas MES (Manufacturing Execution System)
- Sistema SCADA, Supervisory Control and Data Acquisition
- Los PLC (Controladores Lógicos Programables) como sensores y actuadores

- Crear un Diagrama de Bloques gráfico de la Empresa Ficticia según la estructura pedida en el que se distribuyan los activos de la lista anterior, es decir, un esquema general de los equipos distribuidos en la red según esta estructura en trípode.

Para la realización de este diseño se puede usar la herramienta que se considere más idónea. Se recomienda el uso de draw.io que viene integrada en el Drive de Google o se puede optar por otras alternativas integradas en suites ofimáticas.

Una vez completado el diagrama, exporta la imagen del mismo. Este diagrama formará parte de la solución que entregarás en este apartado.



Apartado 2: Detalle de los Activos Clave que se deberán auditar.

Para llevar a cabo una auditoría efectiva, es fundamental identificar y documentar los activos clave de la empresa ficticia. Estos activos comprenden tanto elementos de hardware como de software que juegan un papel esencial en el funcionamiento seguro y eficiente de la infraestructura de TI y OT de la organización.

Para este apartado, deberás realizar un inventario de los activos clave, recopilando la información necesaria en una tabla para los activos que consideres necesarios, tomando un activo por cada zona (LAN, DMZ, Smart Factory) más un activo transversal que pudiera estar en más de una zona o sea perimetral.

Completa la siguiente tabla de inventario para cada uno de los activos seleccionados. La tabla debe incluir los datos esenciales de cada activo, tales como:

Zona	Nombre Activo	Dirección IP/Rango de IP	Sistema Operativo	Modelo de Máquina	Función en la Empresa	Observaciones
Perimetral	Router Frontera	192.168.1.1	Askey	RTF3505 VW	Router de conexión a Internet	LAN, WiFi habilitado
LAN	Sistema de bases de Datos ERP	192.168.2.1	Linux Red Hat	HPE ProLiant DL145 Gen11	Almacenamiento y gestión de datos	Acceso sólo a administradores y backups automáticos
DMZ	NAS	192.168.2.5	Synology DiskStation Manager (DSM)	Synology Diskstation DS224 NAS	Almacenamiento y backups	Acceso desde SOC y laboratorio. Habilitar cifrado.
Smart Factory	PLC	192.168.2.10	Firmware Siemens	Siemens S7-1200	Controlar máquinas de producción	Aislado de Internet
Activo Transversal	Firewall	10.0.0.1	Palo Alto PAN-OS	Palo Alto PA-820	Segmentación entre los activos	Políticas de inspección y control

- Este inventario de activos será esencial para los siguientes apartados, donde se definirán las comprobaciones de seguridad y los procedimientos de auditoría específicos para cada uno de estos activos.

Apartado 3: Comprobación prioritaria a efectuar para cada uno de los activos anteriores.

Una vez que se ha realizado el inventario de los activos clave, es necesario definir las comprobaciones de seguridad que se deben efectuar sobre cada uno de ellos. Estas comprobaciones buscan identificar vulnerabilidades y asegurar que los activos cumplen con las medidas de protección adecuadas para minimizar riesgos de ciberseguridad.

A continuación, se detallan algunas de las principales comprobaciones de seguridad aplicables a los activos de la empresa ficticia:

- Sistemas Antimalware: Verificación de software antivirus y antimalware.
- Gestión de Permisos: Revisión de permisos de acceso y privilegios de usuario.
- Cumplimiento Legal (Compliance): Asegurar que el activo cumple con normativas de ciberseguridad.
- Prevención de Fraude y Fuga de Datos: Comprobación de medidas de protección contra fraudes y exfiltración de datos.
- Sistema de Actualizaciones: Verificación de políticas de actualización y parches de seguridad.
- Monitorización de Recursos: Revisión de herramientas de monitoreo en tiempo real de rendimiento y actividad.
- Protección de Datos / Propiedad Intelectual (PD/PI): Asegurarse de la protección de datos sensibles y propiedad intelectual.

Para cada activo seleccionado en el apartado anterior tienes que elegir una de las comprobaciones de seguridad aplicables de esta lista mostrada. Cada activo debe tener relacionada una comprobación diferente, por lo que no pueden repetirse. Para cada par de activo-comprobación se debe rellenar una ficha con la siguiente información:

- Zona.
- Activo.
- Comprobación a realizar.
- Objetivo de la comprobación.
- Herramientas para efectuar comprobación.
- Criterio de aceptación de la comprobación (PASS/FAIL).

**Ejemplo de ficha (basado en el activo de referencia del Apartado 2):*

- **Zona:** DMZ (Perímetro)
- **Activo:** Router Frontera — Askey RTF3505VW — 192.168.1.1
- **Comprobación a realizar:** Monitorización y registros centralizados (SIEM/logs)
- **Objetivo de la comprobación:** Garantizar que el router perimetral envía registros de tráfico/seguridad al SIEM con retención adecuada y que existen alertas operativas ante eventos críticos.
- **Herramientas:** Panel Askey (Syslog), SIEM (p. ej., Wazuh/Elastic/Graylog).
- **Procedimiento:**
 1. Validar en el panel del Askey la configuración de Syslog remoto (IP/puerto del SIEM, facility/severity, hora sincronizada).
 2. En el SIEM, confirmar la fuentes de logs del router y la retención configurada (≥ 90 días).
 3. Generar un evento de prueba (p. ej., intento de acceso fallido a la consola o un ping bloqueado por firewall) y verificar su ingestión.
 4. Comprobar que los campos clave (origen/destino, acción, timestamp) se parsean correctamente y son consultables.
- **Criterio de aceptación (PASS/FAIL):** PASS si los eventos llegan al SIEM en < 1 minuto, con campos parseados y retención ≥ 90 días; FAIL si no se reciben, no se parsean o no existe retención definida.

Respuesta:

**Ficha (basado en el activo de referencia del Apartado 2):*

- **Zona:** LAN
- **Activo:** Sistema de bases de Datos ERP — HPE ProLiant DL145 Gen11 — 192.168.2.1
- **Comprobación a realizar:** Gestión de permisos
- **Objetivo de la comprobación:** Garantizar que solo puedan acceder a la base de datos usuarios que estén autorizados, para evitar accesos maliciosos
- **Herramientas:** Un gestor, por ejemplo, PostgreSQL y ejecutar scripts SQL para la auditoría
- **Procedimiento:**
 1. Revisar permisos y roles.
 2. Validar cuentas con permisos elevados.
 3. Aplicar por ejemplo MFA (doble autenticación)
 4. Verificar logs.
- **Criterio de aceptación (PASS/FAIL):** PASS si no hay usuarios con permisos muy elevados y además que las cuentas estén justificadas.

-
- **Zona:** DMZ
 - **Activo:** NAS — Synology DiskStation Manager (DSM) — Synology Diskstation DS224 NAS — 192.168.2.5
 - **Comprobación a realizar:** Protección de datos
 - **Objetivo de la comprobación:** Asegurar que la documentación sensible esté cifrada, que tenga copias seguras y que el acceso sea controlado o restringido.
 - **Herramientas:** Synology DSM, panel de cifrado, control de permisos, revisión de snapshots.
 - **Procedimiento:**
 1. Comprobar el cifrado de archivos sensibles.
 2. Controlar los permisos de acceso por grupo.
 3. Comprobar que hay backups.
 4. Comprobar que el acceso remoto no está habilitado.
 - **Criterio de aceptación (PASS/FAIL):** PASS si los datos sensibles están cifrados y solo son accesibles por usuarios o grupos autorizados.
-

- **Zona:** Smart Factory
- **Activo:** PLC - Siemens S7-1200 - 192.168.2.10
- **Comprobación a realizar:** Sistemas actualizados
- **Objetivo de la comprobación:** Asegurar que el PLC esté actualizado y que no tenga ninguna vulnerabilidad.
- **Herramientas:** TIA Portal, firmware Siemens.
- **Procedimiento:**
 1. Comprobar la versión actual.
 2. Compararla con el repositorio oficial.
 3. Validar si hay algún parche.
 4. Registrar si hace falta una actualización programada.
- **Criterio de aceptación (PASS/FAIL):** PASS si el firmware está actualizado.

Apartado 4: Auditoría prioritaria por activo (una por cada activo, sin repetir tipo)

Selecciona para cada uno de los cuatro activos (LAN, DMZ, OT y Transversal) **un único tipo de auditoría**, priorizando la que mejor cubra el riesgo principal del activo. No puede repetirse el tipo de auditoría entre activos. La elección puede estar **alineada** con los posibles hallazgos del Apartado 3.

Tipos de auditoría disponibles (elige 1 diferente por activo):

- **Test de penetración (Hacking Ético):** identificación de vulnerabilidades explotables (en laboratorio, con alcance controlado).
- **Auditoría de red:** revisión de diseño/segmentación, enrutamiento y servicios expuestos.
- **Seguridad perimetral:** validación de controles en frontera (firewall, WAF, VPN, reglas y gestión).
- **Auditoría web:** revisión de aplicaciones/servicios web (sin explotación; baseline de seguridad).
- **Auditoría forense:** procedimiento post-incidente y preservación de evidencias.
- **Auditoría legal (Compliance):** adecuación a normativa aplicable (p. ej., protección de datos y privacidad).
- **Revisión de logs:** análisis de registros y correlación en SIEM para detectar anomalías.

Reglas: (1) una auditoría por activo; (2) las cuatro auditorías elegidas deben ser todas distintas.

Campos a cumplimentar en la ficha (por cada par activo–auditoría):

- **Zona:** LAN / DMZ / OT / Transversal.
- **Activo:** exactamente como en el inventario del Apartado 2.
- **Tipo de auditoría seleccionada:** (una de la lista anterior, sin repetir entre activos).
- **Justificación de elección (2–4 líneas):** vincula la elección con el principal riesgo o motivo.
- **Alcance y limitaciones:** qué se incluye/excluye, rangos IP/URLs, entorno (lab/producción), restricciones de intrusividad.
- **Procedimiento (3–7 pasos):** pasos concretos y reproducibles para ejecutar la auditoría.
- **Herramientas:** herramienta principal (y opcionalmente una de apoyo).
- **Criterios de aceptación (PASS/FAIL):** condiciones medibles (3–5 ítems) que determinen el resultado.

**Ejemplo de auditoría (basado en el activo de referencia del Apartado 2):*

- **Zona:** DMZ (Perímetro)
- **Activo:** Router Frontera — Askey RTF3505VW — 192.168.1.1
- **Tipo de auditoría seleccionada:** Seguridad perimetral
- **Justificación de prioridad (2–4 líneas):** Dispositivo de frontera con impacto directo en la superficie de exposición de toda la organización. Cerrar servicios no necesarios, validar reglas y asegurar la gestión restringida reduce el riesgo de intrusiones y facilita la detección temprana (coherente con hallazgos del Apartado 3).
- **Alcance y limitaciones:** Revisión de configuración (firewall/NAT/gestión), validación de superficie expuesta desde una red externa *simulada* y verificación de gestión segura desde red de

administración. Sin pruebas de DoS/estrés ni fuerza bruta. Ventana de mantenimiento en laboratorio.

- **Procedimiento (3–7 pasos):**
 1. **Exportar** o documentar la configuración actual (reglas de firewall, NAT/port-forward, UPnP, administración remota, VPN).
 2. **Revisar reglas:** política por defecto “deny-all”, permitir solo tráfico necesario (allowlist), revisar DMZ↔LAN y WAN↔DMZ.
 3. **Gestión segura:** confirmar que la consola solo es accesible desde red de administración, credenciales robustas, MFA (si disponible), y *administración remota por WAN* deshabilitada.
 4. **Validar exposición** desde un host externo de laboratorio con **nmap -sV -Pn <IP WAN/host publicado>** para confirmar que solo hay puertos esperados (p. ej., 443 si procede).
- **Herramientas:** Consola Askey (config/backup), **nmap** (descubrimiento no intrusivo), visor del SIEM (Wazuh/Elastic/Graylog) para confirmar ingestión.
- **Criterios de aceptación (PASS/FAIL):**
 - Sin administración remota por WAN; gestión solo desde red de administración.
 - Puertos WAN expuestos = únicamente los justificados.
 - Política “deny-all” y allowlist explícita en reglas; NAT sin redirecciones innecesarias.
 - Syslog activo hacia SIEM; eventos del router visibles y con timestamp correcto.

Auditorías escogidas y ejemplos. Respuesta:

**Auditoría (basado en el activo de referencia del Apartado 2):*

- **Zona:** LAN (TI)
- **Activo:** Servidor de Bases de Datos ERP — HP ProLiant DL385 — 10.0.10.25
- **Tipo de auditoría seleccionada:** Auditoría legal (Compliance)
- **Justificación de prioridad (2–4 líneas):** Al gestionar datos sensibles, como económicos o datos personales, el mayor riesgo es no cumplir la RGPD ya que un mal control sobre los datos puede tener un impacto legal.
- **Alcance y limitaciones:** Revisión de documentos y protección de datos como el cifrado, permisos. Limitar test de intrusión en producción.
- **Procedimiento (3–7 pasos):**
 1. Revisar las medidas aplicadas en la protección de datos, como el cifrado.
 2. Validar la política de registros de acceso.
 3. Revisar los permisos de administradores y usuarios.
 4. Comprobar los backups y la política de conservación de los mismos.
- **Herramientas:** Consola de PostgreSQL, logs del servidor...
- **Criterios de aceptación (PASS/FAIL):**
 - PASS si datos personales están cifrados.
 - PASS si permisos están documentados y justificados.
 - PASS si backups cumplen retención establecida.
 - FAIL si falta cualquiera de las medidas anteriores.

-
- **Zona:** DMZ
 - **Activo:** NAS — Synology DiskStation Manager (DSM) — Synology Diskstation DS224 NAS — 192.168.2.5
 - **Tipo de auditoría seleccionada:** Revisión de logs
 - **Justificación de prioridad (2–4 líneas):** En el NAS se almacena documentación sensible y debe detectarse el acceso indebido. Hay que garantizar que los logs estén monitorizados.
 - **Alcance y limitaciones:** Revisión de logs locales. No se borra ni se modifican.
 - **Procedimiento (3–7 pasos):**
 1. Validar que el NAS genera logs de acceso, cambios y fallos.
 2. Revisar configuración de Syslog y destino SIEM.
 3. Confirmar que los logs llegan al SIEM con timestamp correcto.
 4. Buscar patrones de accesos sospechosos en las últimas 48 h.
 5. Verificar retención ≥ 90 días.
 - **Herramientas:** Synology DSM, visor SIEM
 - **Criterios de aceptación (PASS/FAIL):**

- PASS si los logs llegan al SIEM.
 - PASS si los eventos tienen timestamp correcto.
 - PASS si la retención es ≥ 90 días.
 - FAIL si hay huecos o pérdida de logs.
-

- **Zona:** PLC
 - **Activo:** PLC - Siemens S7-1200 - 192.168.2.10
 - **Tipo de auditoría seleccionada:** Auditoría de red
 - **Justificación de prioridad (2–4 líneas):** El PLC debe estar en una red OT (Tecnología de las operaciones) segmentada. El mayor peligro es un acceso no autorizado desde otras zonas, por lo que hay que revisar el tráfico de red.
 - **Alcance y limitaciones:** Reglas de firewall, chequear puertos necesarios y no se permite el escaneo intrusivo.
 - **Procedimiento (3–7 pasos):**
 1. Revisar diagrama de red OT y tablas de enrutamiento.
 2. Validar las reglas del firewall entre OT y otras zonas.
 3. Confirmar que únicamente la estación de ingeniería puede comunicarse con el PLC.
 4. Revisar puertos necesarios (S7Comm, Profinet).
 5. Analizar tráfico pasivo en el switch OT durante 10–15 min.
 - **Herramientas:** TIA Portal, firewall OT.
 - **Criterios de aceptación (PASS/FAIL):**
 - PASS si solo existe tráfico permitido hacia dispositivos autorizados.
 - PASS si no hay rutas LAN
 - FAIL si aparece tráfico inesperado o puertos abiertos innecesariamente.
-

- **Zona:** Transversal
- **Activo:** Firewall - Palo Alto PA-820 - 10.0.0.1.
- **Tipo de auditoría seleccionada:** Seguridad perimetral
- **Justificación de prioridad (2–4 líneas):** Básicamente es el control central entre todas. El mayor riesgo es que esta permita el tráfico indebido entre zonas hacia internet. Hay que validar las reglas del firewall.
- **Alcance y limitaciones:** Revisión de reglas, perfiles de seguridad, VPN... Se harán validaciones no intrusivas.
- **Procedimiento (3–7 pasos):**
 1. Revisar políticas entre zonas.
 2. Validar las reglas de IPS.
 3. Revisar NAT y servicios expuestos desde DMZ.

4. Comprobar VPN y accesos.
 5. Escaneo no intrusivo desde una máquina de pruebas.
- **Herramientas:** PAN-OS, nmap ...
 - **Criterios de aceptación (PASS/FAIL):**
 - PASS si solo están abiertos los puertos necesarios
 - PASS si se cumplen las reglas de segmentación entre zonas
 - PASS si la VPN está configurada correctamente
 - FAIL si aparece algún servicio expuesto o una regla indebida.

Webgrafía:

- <https://es.linkedin.com/pulse/protege-tu-empresa-con-dmz-perfectnumbers>
- <https://ascentoptics.com/blog/exploring-the-functions-of-gpon-olt-and-ont-in-optical-line-terminal-network/#>
- <https://www.conceptdraw.com/examples/routers-with-block-diagram>
- <https://www.mydraw.com/diagrams-network-diagram>
- <https://www.siemens.com/ar/es/productos/automatizacion/software-industrial/tia-portal.html>
- <https://www.synology.com/es-es/dsm>
- <https://www.digitizeme.blog/digitizeme-latam/redes-ot-qu%C3%A9-son-y-c%C3%B3mo-se-protegen-con-ciberseguridad>
- <https://telenorcomunicaciones.com/es/servicios-de-telecomunicaciones/ciberseguridad/firewall-ot>
- <https://support.catonetworks.com/hc/es/articles/4413280528529-Permitido-de-firmas-IPS>